

TO: National Security Council
FROM: Order of the Purple Flamingo Task Force
[David Simeone, Nabeel Ahmed, Uzair Khan, Andy Valdez, Matt Kwiatkowski]
SUBJECT: Assessment of Concerning Cyber Activities Threatening Critical Infrastructure Operations



SITUATIONAL ASSESSMENT

- **Critical infrastructure devices**, mainly within **water treatment networks**, face threats from **state-backed actors**. Many of the devices being targeted are **unpatched, unsupported, and considered End-of-Life**, allowing attackers to **exploit known vulnerabilities** to establish persistence.
- The goal of this threat actor appears to be **strategic pre-positioning**, with efforts suggesting a focus on **having a long-term effect on IT and OT systems**. There is some **public concern** surrounding the **insecurity of critical infrastructure** systems.
- Meanwhile, a new **ransomware class**, “**RUGRAT**,” targeted certain **critical infrastructure operators and large businesses**, proliferated by an **unattributed threat actor** that likely **differs from the aforementioned** pre-positioning actor.
- There is a call for **public-private cooperation** between affected organizations, cloud providers, and law enforcement to **identify and eradicate these threats**. Some cloud providers have set an example by **proactively detecting and terminating** accounts associated with the threads in collaboration with law enforcement.

KEY SECURITY CONCERNS

[HIGH] (Concern 1) Cascading failures due to water sector vulnerabilities and sector interdependence

- The underfunded, fragmented, and aging nature of our water sector poses a systemic risk. A coordinated attack on these vulnerabilities could trigger cascading failures across interdependent industries. This dynamic creates a dangerous feedback loop: as critical manufacturing and energy sectors are compromised, their ability to support water infrastructure recovery is diminished, prolonging the crisis.
- Water system disruptions can not only halt drinking supply, but also impact business consumers, such as power generation, manufacturing, and data centers. Beyond outages, attackers can manipulate treatment chemicals to taint supplies, creating a biological hazard. Overall, this presents a major risk of compounding crisis response efforts and costs.
- The success of Volt Typhoon’s relatively routine tactics against water infrastructure serves as a warning: future breaches may occur more often and with a much broader impact on vast populations and national security.

[MEDIUM] (Concern 2) Adversarial prepositioning activities within critical infrastructure operations

- A sophisticated, state-sponsored APT group has quietly established persistence across U.S. water utilities and their operational systems, with the potential to cause a strategic disruption. While the scale of their prepositioning is yet to be fully determined, the threat is confirmed, immediate, and can have a widespread impact on human safety and the environment.
- The TTP’s used by this group are similar to those of the Volt Typhoon APT; however, no formal association has been recognized at this time. Instead, this new actor has been designated the identifier “**PESTIS**” by authorities. While currently dormant, this group has the ability to continue infiltrating new targets and begin causing severe disruptions at any moment.
- These operations are being supported by a botnet of compromised network edge devices performing reconnaissance, scanning, and target identification operations. Most of these devices are SOHO and/or end-of-life, leaving them vulnerable.

[LOW] (Concern 3) The Ransomware-as-a-Service ecosystem and new RUGRAT campaign

- Over the past few years, the barrier to entry for attackers looking to start their own ransom campaign has been lowered significantly thanks to peer-to-peer cybercriminal marketplaces, which offer ready-made payloads for relatively low prices.
- A new class, assigned the moniker “**RUGRAT**” by CISA, has been used to attack domestic targets, including a municipal water treatment facility, urgent care providers, and several other large domestic businesses via highly targeted phishing. The ransomware relied on misconfigurations and CVE exploitation to maintain persistence and extort the victims for Bitcoin.
- CISA asserts that the RUGRAT class of ransomware stems from a common threat actor not associated with any other known ransomware groups. This is concerning, as ransomware-as-a-service providers can allow resource-constrained countries to project significant power, while simultaneously making attribution difficult via the use of shared TTP’s.
- A private cloud provider detected RUGRAT C2 traffic on their networks, and proactively took action to contact law enforcement and terminate the offending account. This accelerated the recovery of victims and also stalled new infections. Further public-private cooperation is being encouraged, but operations must be handled with extreme care and caution.

POLICY AND ACTION RECOMMENDATIONS

It is recommended that the NSC **proceed with immediate tasks first**. The NSC may consider short-term and medium-term actions based on **unfolding events and escalations to dynamically adapt to the situation**. Long-term actions are for future NSC consideration and may be **executed when necessary** resources are available.

Investigate & Prepare	
Immediate	Short-Term
(Concern 2) <u>Confidential Water Sector Reporting Directive (CISA, FBI)</u> - The NSC directs CISA and FBI to warn Water Sector operators via WaterISAC and InfraGard of prepositioned threats. This non-public notice must confirm that voluntarily sharing threat indicators triggers CISA 2015 and CIRCIA protections: civil immunity, disclosure exemptions, and a ban on regulatory enforcement. (Concern 2) <u>Establish an Interagency Coordination Cell (NCIJTF, DOJ)</u> - Establish a temporary coordination cell to assess legal authorities (Rule 41, preservation, voluntary action), synchronize investigative and disruption timelines, and issue cloud providers clear, written guidance.	(Concern 1) <u>Create Nationwide Asset Vulnerability Mapping for Water Utilities (CISA, EPA)</u> - Direct CISA, in coordination with EPA, to timely map internet-exposed OT assets, end-of-life edge devices, and known vulnerable vendor/third-party equipment in the water sector. (Concern 2) <u>Investigate the Cause of the Leaked CISA Report (FBI)</u> - A classified internal CISA report was leaked to the public. The NSC and FBI should look into this leak and find the source to prevent more exposures. (Concern 3) <u>Identify the traffic pattern of RUGRAT C2 and infections (CISA, Industry)</u> - Using observations from known infections, private cybersecurity organizations can build network filters to detect more ransom operations.
Mitigate	
Immediate	Medium-Term
(Concern 2) <u>Press Release (FBI)</u> - To de-escalate fear in the public and prevent the spread of false information, a statement should be put out by the FBI regarding infrastructure security, without disclosing any sensitive technical details. (Concern 2/3) <u>Voluntary Cloud Provider Security Framework (CISA, DHS, Industry)</u> - Direct DHS, through CISA, to issue temporary guidance to cloud providers for identification, validation, and forensic preservation of suspected malicious infrastructure, with reversible containment actions only after federal coordination.	(Concern 2) <u>Emergency CSIRT Deployment (CISA, DHS)</u> - Using the Cyber Response and Recovery Fund, provide a CSIRT for the largest at-risk water treatment plants to assist with OT monitoring and mitigation implementation. (Concern 3) <u>Collaborative Decryptor Development (FBI, Industry)</u> - If appropriate, the FBI may choose to share benign samples and binary artifacts from RUGRAT infections with industry analysts to determine the viability of developing a universal decryption program.
Reinforce / Remediate	
Short Term	Long Term
(Concern 1) <u>Update Cyber Awareness Training (CISA, Industry)</u> - CISA shall post a bulletin heavily encouraging at-risk infrastructure operators to train employees on identifying anomalous behavior that may indicate system compromise, as per the recent WaterISAC Advisory. (Concern 1) <u>Implement Standard Cyber Hygiene for Water Sector Utilities (CISA, EPA, NIST)</u> - Direct CISA and EPA to create baseline security controls, including inventories of assets, network segmentation, and centralized logging and monitoring of water systems. These controls can be catalogued and standardized by NIST.	(Concern 2) <u>Establish New Auditing Procedure (EPA)</u> - Third-party audits can maintain critical infrastructure integrity by reviewing cyber defenses. (Concern 2) <u>Prepare Outreach to Industrial Equipment manufacturers (CISA, DHS)</u> - Prepare high-level channels with equipment providers to discuss and plan intense remediation techniques if the situation escalates severely. (Concern 3) <u>Expand Public-Private Intelligence Sharing Model (Industry)</u> - Expand WaterISAC/HealthISAC-like models to share threat intelligence information as appropriate to enable faster cross-sector reporting.

Timeline Legend

- | | |
|--|---|
| <ul style="list-style-type: none"> • Immediate: Start within 3-5 business days • Short Term: Occurs in 1-2 weeks | <ul style="list-style-type: none"> • Medium Term: Occurs in 2-3 months • Long Term: Starts in 6+ months |
|--|---|